1.125 AGENTIC ENGINEERING · PROBLEM SET 06 TERM PROJECT PROPOSAL

XFAIR

Cross framework readiness for AI agents in critical infrastructure

How much autonomy can an operator safely give an AI agent, under NIST CSF 2.0, NIST AI RMF, EU AI Act and NIS2?



Iva Biscanic · 29 October 2026

CONTEXT · REGULATION TODAY

The US guides, the EU legislates

United States

- No binding federal AI law: NIST AI RMF and CSF 2.0 are voluntary
- NIST's Cyber AI Profile and AI agent standards are still drafts
- Executive Order 14365 (Dec 2025) pushes back on state AI laws, but creates no binding federal rules
- Colorado and California AI laws already apply

Direction: speed and a light touch

European Union

- The AI Act is binding law
- Digital Omnibus (in force July 2026): high-risk duties for critical infrastructure start 2 December 2027
- NIS2: 24-hour early warning, 72-hour notification; boards personally accountable
- Uneven rollout: 21 of 27 states had transposed NIS2 by May 2026

Direction: binding duties and deadlines

Sources: White & Case (EO 14365); National Law Review (AI Omnibus); Ciphers Security (NIS2, Aug 2026)

CONTEXT · THE GAP

For US firms in Europe, NIST is not enough

Issue	Typical US practice	EU requirement
Legal status	Voluntary frameworks	Binding law, fines up to €10M or 2% of turnover
Incident clock	Internal escalation of 72–96 hours	24-hour early warning, 72-hour notification
Accountability	Led by the security team	Board approves, is trained, is personally liable
Rulebook	Federal guidance plus state laws	27 national NIS2 laws, different authorities

Covered, but not explained: AI rules and cyber rules already apply to AI agents (the European Commission confirms it for the AI Act), but none says how for autonomy, tool use, delegation or agent identity, and very fragmented practical US – EU mapping links them.

Sources: Ciphers Security, NIS2 for US companies (Aug 2026); EU AI Act Service Desk FAQ on AI agents

01 · PROBLEM AND AUDIENCE

Operators want AI agents that act. Nobody can say how far it is safe to let them.

AI and cyber rules, in silos

AI rules (AI Act, AI RMF) set duties; cyber rules (NIS2, CSF 2.0) hold the controls. Both cover agents, neither says how.

Rules keep changing

New guidance every month; EU high-risk duties now apply from December 2027.

Tools cover only pieces

Trackers inform, crosswalks are static, governance platforms assess “AI” in general, not agents acting on live systems.

Who it is for

Primary: risk, compliance and security leads at critical infrastructure operators in the US and EU.

Secondary: consultants, researchers.

“We follow NIST.
Is our agent ready to act alone, and what else does the EU need?”

02 · PROPOSED SOLUTION

XFAIR: one crosswalk links a tracker to readiness

STAGE 1

Regulatory tracker

Agents follow AI and cyber rules in the US and EU (NIST, CISA, NIS2, CRA, CIRCIA) and write source-backed entries.

STAGE 1

AI–cyber crosswalk

Pairs each AI duty with the cyber control that proves it; every link labeled by legal status.

STAGE 2

Readiness assessment

Starts with an agent charter; readiness for each action at the autonomy level wanted, per framework.

Autonomy levels Recommend → Act with approval → Act alone — set per action, not per agent

A user can: write an agent charter · get readiness per action and framework · get onepager and US–EU gap reports · compare incident clocks · see how a new rule changes readiness.

IN PRACTICE · MEET MARIA

Maria’s water utility wants an AI agent in its control room



Maria runs operations at a small water utility with a team of five. A vendor offers an AI agent that could take on three jobs. XFAIR’s answer is a plan, not a yes or no:

Send leak alerts
Watches sensors; every alert is logged

Ready now · on its own

Adjust pump schedules
To save energy, with each change logged

Ready · with Maria’s OK

Close valves after a leak
Missing: its own login, a way to undo, an incident plan

Not yet · advice only

XFAIR · Illustrative example, not a real utility

IN PRACTICE · STEP BY STEP

From agent charter to safe rollout

Every assessment starts with the agent charter. Then XFAIR helps Maria answer five questions.

STEP 1 · START



Write the agent charter

What, where, how freely, who approves

MARIA

Alerts, pumps, valves: the autonomy she wants, who approves

STEP 2



Which rules apply?

XFAIR checks AI and cyber rules

MARIA

Water is critical: NIS2, the AI Act, NIST, CISA

STEP 3



What do they ask for?

Legal duties become concrete safeguards

MARIA

A person can step in; the agent has its own login

STEP 4



Are we ready?

Agents check her documents; a critic double-checks

MARIA

Not quite: it shares a staff login, no undo button

STEP 5



What can it do today?

Clear rules decide; Maria signs off

MARIA

Alerts: alone. Pumps: with her OK. Valves: advice only

STEP 6



What if rules change?

The tracker keeps watch; back to step 2

MARIA

New guidance arrives: XFAIR asks her to recheck valves

ADDED VALUE

What XFAIR adds, gap by gap

Agents in the rules

Today: rules cover agents but never say how

With XFAIR: duties become agent-specific safeguards

AI and cyber

Today: separate teams, separate checklists

With XFAIR: each AI duty paired with the cyber control that proves it

All or nothing

Today: approve or reject the whole agent

With XFAIR: autonomy decided per action

Legal certainty

Today: binding, optional and unclear mixed together

With XFAIR: every finding labeled binding, interpretive, voluntary or open

US and EU

Today: following NIST and CISA taken as EU compliance

With XFAIR: shows what a US-aligned operator still owes under the EU AI Act, NIS2 and CRA

Rules change

Today: assessments go stale without anyone noticing

With XFAIR: the tracker flags changes and triggers reassessment

Who gains: operators decide faster and more safely · assessors reuse one method · policymakers see where rules are still open

03 · APPROACH

Agents gather and explain, rules decide, a human approves

Monitoring agent → **Drafting agent** → **Critic agent** → **Rules file** → **Human approval**

Part	Planned choice
Language and models	Python + OpenAI API: small model to monitor, stronger model to assess
Orchestration	Python pipeline; an agent framework
Sources	Federal Register, NIST, CISA, EUR-Lex; AI Act, NIS2, CRA, CER, CIRCIA
Reference crosswalks	CSA AI Controls Matrix v1.1, NIST crosswalks: referenced and checked
Retrieval	Texts split by article, embeddings, local vector store; every claim referenced
Data and decisions	Versioned JSON/CSV entries; readiness rules in a readable YAML file
Interface and logs	Public tracker site, Streamlit review app, replayable JSON run logs

04 · SCOPE AND RISKS

Finish the tracker first, then readiness

Stage 1 · core, before midpoint

- Tracker: 30–50 entries on AI and cyber rules: AI Act, NIS2, CRA, CER, NIST, CISA, CIRCIA
- AI cyber crosswalk: AI Act, AI RMF, NIS2, CSF 2.0; 8 themes; links labeled by legal status
- Public site with a method page

Stage 2 · after midpoint

- Synthetic use case
- Agent charter; readiness per action
- Incident view: all reporting regimes side by side

Stretch and out of scope

Stretch: full CRA and CER crosswalk. **Out:** other sectors, real client data, legal advice

What could prevent success, and the fallback

Risk	Mitigation
Wrong facts or citations	An exact source passage for every claim; only approved items are published
Too much for one person	Stage 2 shrinks to a prototype; the tracker stands on its own
Results vary between runs	Fixed model settings; the rules file carries the decision
No programming background	Simple stack, cited AI coding help, patterns reused from PS4
Rules change mid-project	Versioned entries with a change history

05 · PLAN AND SUCCESS CRITERIA

Three milestones, four measures of success

Before midpoint · [TBD]

- Monitor and draft pipeline
- Approved entries
- Crosswalk for themes
- Tracker site, version 1

Midpoint · [TBD]

- Working repo and demo
- Citation accuracy tested
- Run consistency tested
- Plan for the rest

Final · [TBD]

- 50 entries, 8 themes
- Readiness by autonomy level
- Onepager, gap and impact views
- Evaluation and README

Tracker

Entries checked against official texts; target: 90%+ need no factual fix

Crosswalk

Against 30 hand-built links: correct, missed, citations right

Readiness

4 evidence variants: agrees with my expert judgment, stable across runs

Better decisions?

Clinic assessors decide with and without XFAIR: compare time, gaps found, confidence

Final demo: a new rule enters the tracker, and the operator’s readiness changes live.

APPENDIX A · HOW AI AND CYBER CONNECT

AI rules say what; cyber frameworks show how

Control theme	AI rule (the duty)	Cyber control (the evidence)	Legal status
Agent identity and permissions	AI Act Art. 14 human oversight	CSF 2.0 PR.AA identity and access; NIS2 Art. 21 access control	Open question: identities that decide
Logging and records	AI Act Art. 12 record-keeping	CSF 2.0 DE.CM monitoring; NIS2 Art. 21	Binding (EU high-risk); voluntary (US)
Incident reporting	AI Act Art. 73 serious incidents	NIS2 Art. 23 (24 h / 72 h); CIRCIA (72 h)	Binding; CIRCIA rule pending
Robustness and manipulation	AI Act Art. 15 robustness and cybersecurity	NIST Cyber AI Profile (draft); CISA guidance	Binding (EU high-risk); draft and voluntary (US)
Supply chain and vendors	AI Act deployer and provider duties	CSF 2.0 GV.SC; NIS2 Art. 21; Cyber Resilience Act	Binding (EU); voluntary (US)

Four labels on every link: binding obligation · interpretive judgment · voluntary guidance · unresolved question

APPENDIX B · RELATED WORK

Each piece exists; the combination does not

Category	Examples	What is missing
AI regulation trackers	IAPP Global AI Law and Policy Tracker; White & Case AI Watch	Inform only; not linked to controls or readiness; AI only, not cyber
Crosswalks and control matrices	CSA AI Controls Matrix v1.1; NIST crosswalks	Static tables; rarely combine NIS2 and CSF 2.0 with AI rules
AI governance platforms	Credo AI, Holistic AI, Modulos, ModelOp	General enterprise AI; closed methods; not agents in critical infrastructure
Consultancies and law firms	Big Four, law firms	One-off and costly; not continuously updated or public

XFAIR's edge: readiness per autonomy level of an agent · cyber and AI frameworks together · a tracker linked to readiness · an open, referenced method with human approval

APPENDIX C · MIT AND HARVARD

Building on MIT and Harvard work

Resource	What is done	Missing for operators	How XFAIR uses and extends it
MIT · AI Risk Repository	1,600+ AI risks from 65+ frameworks; a shared taxonomy	Lists risks; no readiness decision; no cyber law	Checks XFAIR's 8 control themes; cited as the risk base
MIT · AI Governance Mapping (CSET)	Links laws and policies to actors, risks and mitigations	A landscape view; no autonomy levels or scoring	Cited start for the crosswalk; XFAIR adds autonomy levels
MIT · AI Agent Index	What agent developers disclose about safety	Developer side only, not the deploying operator	Vendor evidence input; XFAIR assesses the deployer
Harvard · Berkman Klein	Research on agentic AI protocols and risk mitigations	Technology and society level; no decision under law	Agent controls inform XFAIR's identity and oversight themes
Harvard · EELP trackers	Public, curated trackers of US federal actions	Environment only; no AI or cyber	The model for XFAIR's public tracker design

Maybe: an operational layer for their work; feedback talks with MIT's AI Risk Initiative and Berkman Klein after the midpoint

Sources: airisk.mit.edu; aiagentindex.mit.edu; cyber.harvard.edu; eelp.law.harvard.edu

APPENDIX D · REPORT STRUCTURE

Each assessment is an onepager report

01 Business context
The planned agent, its target autonomy level, the frameworks that apply

02 Current conditions
Evidence-based readiness per theme, framework and autonomy level

03 Desired outcome
Target autonomy level and the readiness it needs, by a set date

04 Causal analysis
Root causes of each gap, traced to missing evidence, with citations

05 Countermeasures
Options ranked by gaps closed and autonomy level unlocked

06 Action plan
Owners, milestones, resources and deadlines

07 Follow-up and learning
Readiness KPIs; a new tracker entry triggers a review

Agents draft each step; the reviewer approves or edits it.